

## CUSTOMER MILESTONE BRIEF

# MS #62 - CloudBank Production OAuth Application Boundary

Purpose, customer value, delivered capability, evidence, and claim boundaries

|                 |                                                                                      |
|-----------------|--------------------------------------------------------------------------------------|
| <b>Status</b>   | Complete                                                                             |
| <b>Release</b>  | 0.62.0                                                                               |
| <b>Date</b>     | 2026-09-02                                                                           |
| <b>Audience</b> | Customers, partners, executives, architects, delivery teams, and assurance reviewers |

## Executive summary

MS #62 - CloudBank Production OAuth Application Boundary converts a specific part of the LIGHTYEAR modernization approach into a governed, reviewable capability. Replaces the migrated transaction workcell's development authentication shortcuts with a live, restart-safe OAuth 2.0/OIDC boundary that separates customer and service identity.

## Why this matters to a customer

Replaces the migrated transaction workcell's development authentication shortcuts with a live, restart-safe OAuth 2.0/OIDC boundary that separates customer and service identity.

The practical result is a narrower, evidence-backed decision instead of a broad modernization claim. Commercial, architecture, delivery, security, and assurance teams can review the same capability, proof, and limits.

## What the milestone delivers

- A signed MS #61 receipt chain and isolated Authorization, Account, and Transfer target materialized from the exact pinned CloudBank source and generated PostgreSQL transaction target.
- A PostgreSQL user-repository mapping for the CloudBank authorization server with its original OAuth2/OIDC protocol surface retained.
- RSA-3072 JWT issuance through the real client-credentials endpoint with exact issuer, lifetime, signature, service-specific audience, and scope validation.
- Separate caller and service credentials: Transfer accepts cloudbank.transfer for the cloudbank-transfer audience and obtains cloudbank.internal for the cloudbank-account audience.
- Twelve native scenarios covering discovery, JWKS, invalid client, scope escalation, claim binding, missing credentials, scope denial, tamper denial, audience isolation, ownership, value conservation, and signing-key restart continuity.
- Three executable Spring Boot JARs with zero Oracle and zero MicroTx runtime libraries.
- Per-run secrets and signing keys confined to runtime memory or operator-temporary files, loopback-only ports, synthetic data, hashed logs, and safe failure diagnostics.

- Deterministic security, execution, acceptance, compatibility, readiness, and receipt contracts; cross-platform launchers; CI compilation; Control Tower projection; documentation; and adversarial tests.

## How it differs from earlier work

MS #61 established bounded Oracle/PostgreSQL behavior for Customer, Account, and Transfer. MS #62 chains that signed result into the first production-shaped identity workcell while leaving deployment security and unrelated services explicitly gated.

Earlier evidence is not automatically promoted into this milestone. A parser, simulator, local comparison, or generated artifact is not live platform equivalence or production readiness.

## What a customer can do with it

A customer can use cloudbank production oauth application boundary as a bounded decision and delivery capability, attached to approved sources, owners, policies, target architecture, acceptance criteria, and authorized evidence.

Unresolved semantic loss, policy decisions, unsupported behavior, and live-evidence requirements remain visible.

## Evidence and acceptance posture

The repository capability is complete because its committed implementation and release record are present. Customer qualification remains claim-specific and evidence-class-specific.

Review exact source and artifact identities, distinguish development from authorized live evidence, inspect policy and loss classifications, confirm passed and blocked gates, and verify that later changes have not invalidated the evidence.

## Boundaries and claims not made

- The committed readiness receipt proves contract and runner readiness, not that the native OAuth run occurred.
- A passing receipt qualifies the production OAuth application profile for the bounded Authorization, Account, and Transfer workcell, not an operational production deployment.
- The native qualification uses loopback HTTP; approved external TLS termination remains required.
- Managed-secret storage, automated signing-key and client-secret rotation, and revocation operations are not exercised.
- The browser authorization-code flow is configured with PKCE but is not executed by this machine-to-machine gate.
- Enterprise identity-provider federation remains a customer architecture and policy decision.
- Checks AQ/JMS and the remaining services are not migrated or qualified.
- No production data, whole-application equivalence, migration completion, promotion, or production readiness is claimed.

## Source of record

- CHANGELOG.md release section(s): 0.62.0
- README.md product and operating guidance

- LIGHTYEAR-ROADMAP.md governing sequence and claim classifications
- docs/milestones/catalog.json metadata and docs/milestones/manifest.json artifact integrity